PROJET DE LABORATOIRE

Sécurisation d’un réseau d’entreprise

pfSense • OpenVPN • Suricata • Ubuntu Server

Nouhaila El Hamal

Élève ingénieure en sécurité des systèmes d’information

Projet de laboratoire réalisé en mai – juin 2026

Résumé du projet

Conception et évaluation d’un laboratoire réseau combinant accès distant par VPN, filtrage des flux, durcissement d’un serveur Linux et détection d’activités suspectes. Les tests menés depuis Kali Linux ont permis de valider la détection de scans et de tentatives de force brute SSH, tout en mettant en évidence des limites de protection face à une inondation ICMP.

OBJECTIF Sécuriser les accès et réduire la surface d’attaque.	**ENVIRONNEMENT** VirtualBox • pfSense CE 2.8.1 • Ubuntu Server 24.04
RÉSULTATS VPN validé ; scans et force brute SSH détectés.	**POINT D’APPRENTISSAGE** L’inondation ICMP a révélé une limite de détection et de disponibilité.

Compétences mises en pratique

Sécurité réseau | VPN et filtrage | Durcissement Linux | IDS/IPS | Tests de sécurité | Analyse des résultats

Version expurgée destinée au portfolio technique. Les adresses indiquées appartiennent à l’environnement du laboratoire. Les configurations sensibles (clés, certificats et profils VPN) ne sont pas incluses.

1. Objectifs et périmètre

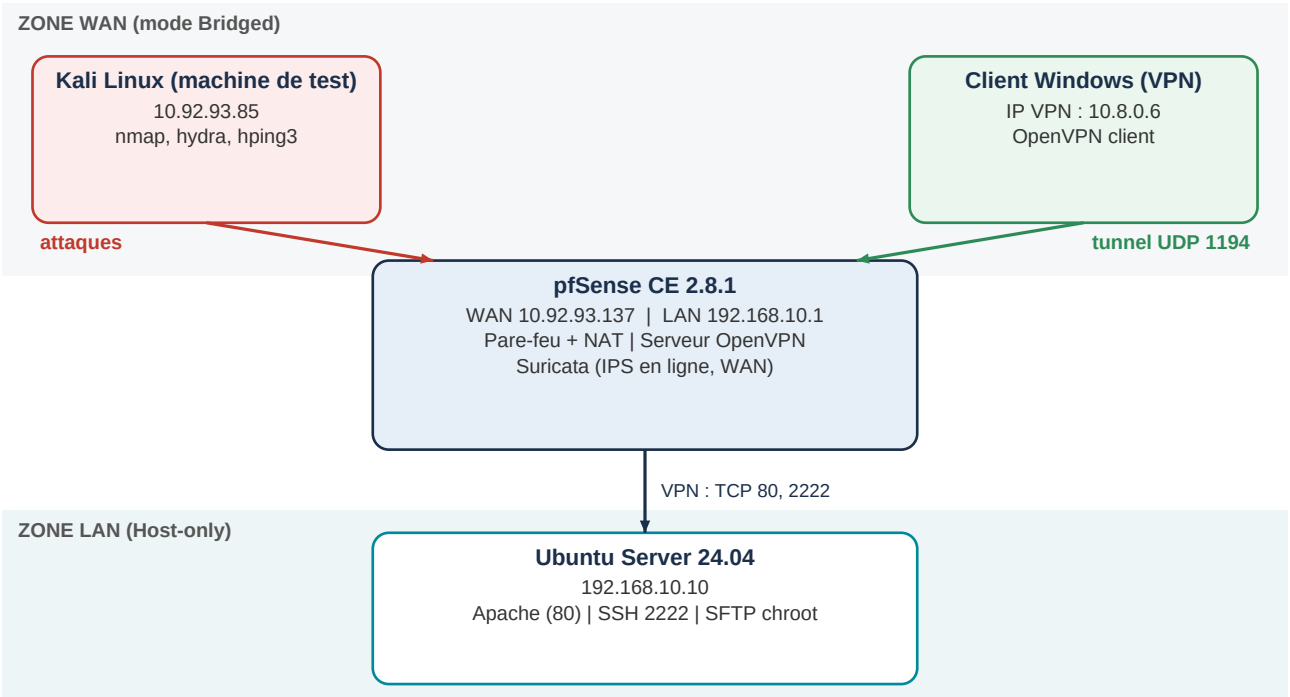
Le projet vise à mettre en œuvre et à évaluer plusieurs contrôles de sécurité complémentaires dans un petit réseau d'entreprise simulé.

- Sécuriser l'accès à distance au réseau interne avec OpenVPN.
- Renforcer la configuration d'un serveur Ubuntu hébergeant des services réseau.
- Détecter des activités de reconnaissance et des tentatives d'accès non autorisé avec Suricata.
- Évaluer le comportement du dispositif lors de tests contrôlés exécutés depuis Kali Linux.

Périmètre des tests Les essais ont été réalisés sur des machines virtuelles utilisées par l'auteure. Les résultats présentés correspondent aux observations du laboratoire ; ils ne constituent pas une certification de sécurité d'un environnement de production.

2. Architecture réseau

pfSense est le point de contrôle entre l'interface WAN et le réseau local. OpenVPN fournit l'accès distant ; Ubuntu Server héberge Apache, SSH et SFTP ; Kali Linux effectue les tests de sécurité ; Windows est utilisé comme client VPN.



Zone	Équipement / rôle	Adresse ou configuration
WAN	pfSense CE 2.8.1	10.92.93.137 (DHCP)
WAN	Kali Linux – machine de test	10.92.93.85
VPN	Client Windows	10.8.0.6
LAN	Interface LAN pfSense	192.168.10.1
LAN	Ubuntu Server 24.04	192.168.10.10 ; Apache, SSH 2222, SFTP

Réseaux utilisés : VPN 10.8.0.0/24 ; LAN 192.168.10.0/24. Les interfaces WAN de pfSense, Windows et Kali utilisent le mode Bridged ; l'interface LAN de pfSense et Ubuntu utilisent le mode Host-only.

3. Accès distant avec OpenVPN

OpenVPN a été configuré sur pfSense en mode client-vers-site afin de permettre à un client distant authentifié d'accéder au réseau interne.

Élément	Configuration et validation
Autorité de certification	CA interne ; RSA 2048 bits ; SHA-256 ; validité de 3 650 jours.
Identités	Certificat serveur et utilisateur VPN muni d'un certificat client.
Transport	UDP/1194 ; tunnel 10.8.0.0/24.
Accès réseau	Réseau interne annoncé : 192.168.10.0/24.
Chiffrement configuré	AES-256-CBC avec SHA-256, selon les paramètres appliqués lors de l'assistant.
Validation	Profil exporté avec openvpn-client-export ; connexion VPN et ping vers Ubuntu validés depuis Windows.

Résultat observé Le tunnel VPN a été établi et la connectivité vers le serveur interne a été vérifiée depuis le client Windows.

4. Durcissement du serveur Ubuntu

Le serveur Ubuntu 24.04 héberge les services Apache, SSH et SFTP. Les mesures ci-dessous limitent les accès, réduisent les services inutiles et appliquent une politique d'authentification plus restrictive.

Domaine	Mesures appliquées / état
Mises à jour et services	Mises à jour système appliquées ; Avahi et Bluetooth non installés.
Paramètres réseau	IPv6 désactivé ; tcp_syncookies=1 ; redirections ICMP désactivées.
UFW	Refus des connexions entrantes par défaut ; TCP/2222 autorisé depuis 10.8.0.0/24 ; TCP/80 autorisé depuis 192.168.10.0/24.
Démarrage et compte root	GRUB protégé par mot de passe PBKDF2 ; compte root verrouillé avec passwd -l.
Mots de passe	Âge maximal de 90 jours ; longueur minimale de 12 caractères ; chiffre, majuscule, minuscule et caractère spécial exigés via pwquality.
Politique de verrouillage	Objectif configuré à valider : 5 échecs puis 15 minutes de verrouillage avec pam_faillock.
SSH	Port 2222 ; connexion root désactivée ; authentification par mot de passe désactivée ; clés SSH uniquement ; MaxAuthTries 3.
SFTP	Groupe restreint avec chroot ; internal-sftp ; redirections désactivées.

5. Filtrage réseau sur pfSense

Les règles de pare-feu contrôlent les communications nécessaires au VPN, aux services internes et aux tests effectués pendant le projet.

Interface	Règle	Finalité
WAN	Blocage ICMP IPv4	Réduire l'exposition aux inondations ICMP.
WAN	Autoriser UDP/1194 vers l'adresse WAN	Permettre OpenVPN.
WAN	Rediriger TCP/2222 vers 192.168.10.10	Démonstration SSH depuis le WAN ; usage limité au laboratoire.
WAN	Bloquer 10.92.93.85	Blocage manuel de la machine de test.
LAN	Blocage TCP/2222 et autorisation ciblée depuis 10.8.0.0/24	Restreindre l'accès SSH au VPN.
OpenVPN	Autoriser TCP/80 et TCP/2222 depuis 10.8.0.0/24	Permettre HTTP et SSH à travers le tunnel.

Point de sécurité à retenir La redirection SSH sur le WAN a été utilisée uniquement pour la démonstration de force brute. Dans un déploiement réel, l'administration SSH doit être accessible exclusivement via le VPN ou un réseau d'administration dédié.

Le verrouillage automatique des comptes via pam_faillock reste à configurer et à valider. Cette mesure doit faire l'objet d'un test fonctionnel distinct.

6. Détection et prévention des intrusions avec Suricata

Suricata est exécuté sur l'interface WAN de pfSense en mode IPS en ligne. Les règles ET Open sont activées, de même que l'option Block Offenders. Quatre règles personnalisées complètent les signatures existantes ; leur contenu est conservé dans *suricata/custom.rules*.

SID	Détection ciblée	Condition configurée
9001	Scan SYN avec Nmap	20 paquets SYN en 2 secondes par source.
9002	Tentatives répétées vers SSH	5 paquets à destination du port 2222 en 60 secondes par source.
9003	Inondation ICMP	50 paquets ICMP en 5 secondes par source.
9004	Scan SYN	20 paquets SYN sans ACK en 2 secondes par source.

7. Tests de sécurité et résultats

Les tests ont été conduits depuis Kali Linux afin d'observer les alertes générées et l'impact sur les services du laboratoire.

Scénario	Outil	Résultat observé
Scan SYN	nmap -sS	Détecté ; le SID personnalisé 9004 apparaît dans les alertes.
Identification des services	nmap -sV	Activité détectée par une règle ET SCAN associée au User-Agent de Nmap Scripting Engine.
Force brute SSH	Hydra + rockyou.txt	Alerte SID 9002 observée. L'authentification par mot de passe étant désactivée, les tentatives utilisant des mots de passe ne pouvaient pas réussir par cette méthode.
Inondation ICMP	hping3 --icmp --flood	Environ 6,5 millions de paquets générés ; aucune alerte SID 9003 observée ; interface Web pfSense temporairement inaccessible ; attaque non atténuée.

Analyse du test ICMP

Le test d'inondation ICMP a révélé une limite importante : la règle personnalisée attendue n'a pas généré d'alerte et l'interface Web de pfSense est devenue temporairement indisponible. La détection et l'atténuation de ce scénario ne sont donc pas considérées comme validées. Une éventuelle influence du traitement IPS en ligne via Netmap reste une hypothèse à vérifier, et non une cause confirmée.

Lecture professionnelle des résultats Les essais confirment des capacités de détection sur certains scénarios, mais montrent aussi pourquoi les résultats doivent être vérifiés à partir des alertes et de l'impact réellement observé, plutôt que déduits de la seule présence d'une règle.

8. Limites identifiées et plan d'amélioration

Les observations du laboratoire permettent de définir des actions concrètes pour renforcer la posture de sécurité et améliorer la qualité de la supervision.

Constat	Amélioration recommandée	Priorité
Ports 80/443 observés ouverts sur l'adresse WAN ; règles WAN permissives pour le laboratoire.	Restreindre l'interface d'administration au LAN/VPN, examiner chaque règle WAN et supprimer les ouvertures non nécessaires.	Élevée
Redirection SSH depuis le WAN utilisée pour les tests.	Supprimer la redirection dans une architecture cible et imposer un accès SSH via VPN ou réseau d'administration.	Élevée
Aucune alerte SID 9003 pendant le test ICMP ; impact sur l'interface Web.	Vérifier la règle en mode IPS en ligne ; tester des limiteurs de trafic, limites d'états et règles de blocage ; documenter les résultats.	Élevée
Blocage automatique Block Offenders non démontré.	Réaliser des tests contrôlés pour vérifier les conditions de déclenchement, le blocage effectif et les éventuels faux positifs.	Moyenne
Pas de collecte centralisée des événements.	Transférer les journaux pfSense/Suricata vers un SIEM (Wazuh ou Splunk), créer des tableaux de bord et des alertes corrélées.	Moyenne
Verrouillage des comptes non validé.	Configurer pam_faillock, tester le seuil de 5 échecs et la période de 15 minutes, puis documenter le comportement.	Moyenne

9. Conclusion

Ce projet a permis de concevoir et de tester un laboratoire de sécurité réseau combinant pfSense, OpenVPN, Suricata et Ubuntu Server. Il met en pratique plusieurs dimensions complémentaires de la cybersécurité : sécurisation des accès distants, filtrage réseau, durcissement Linux, détection d'intrusions et validation par des tests contrôlés.

Les résultats montrent que le VPN est fonctionnel et que certains scénarios de reconnaissance et de force brute SSH sont détectés. Le test ICMP a toutefois révélé une limite de détection ainsi qu'un impact temporaire sur la disponibilité de l'interface d'administration. Ces constats ont été traduits en pistes de travail précises : renforcer l'exposition WAN, valider les règles IPS, éprouver les mécanismes de blocage et centraliser les événements dans un SIEM.

La démarche repose sur l'observation, la vérification des résultats et la documentation des limites. Elle constitue une base pratique pour approfondir des sujets liés à la sécurité des systèmes et réseaux, à la détection et à la réponse aux incidents, ou à la supervision SOC.

Environnement technique

pfSense CE 2.8.1 • OpenVPN • Suricata / ET Open • Ubuntu Server 24.04 • UFW • SSH / SFTP • Kali Linux • Nmap • Hydra • hping3 • VirtualBox

Note de confidentialité : cette version ne contient pas de clés, certificats, profils VPN, captures d'écran ou autres secrets de configuration. Les adresses et détails d'architecture sont fournis dans le seul objectif de décrire le laboratoire.